

RESONANT OS SDK

Final Engineering and Verification Report

SDK-DEMO-003R

T1 through T7 and T7.1

Prepared for Tom, technical reviewer and SDK collaborator

Report date 28 September 2026

Disposition Review and acceptance work complete

Verification Independent exact-SHA PASS, issue #51

Version Final report 1.0

Final accepted candidate

180f3067906d4782df5b923ca46ef77b80828333

Scope: Resonant OS SDK corrections, architectural boundaries, regression coverage and final independent acceptance. Future hardening is recorded separately.

Executive summary

Tom, your SDK review findings have been worked through from T1 through T7, including the T6.1 credential audit and T7.1 graphical-test correction. SDK-DEMO-003R review and acceptance work is complete for candidate 180f3067906d4782df5b923ca46ef77b80828333. Independent exact-SHA verification in work-order issue #51 reports PASS with no source mutation. [E51]

The corrections establish clearer ownership of authority across the Resonant OS SDK. Requests identify an add-on and an intended action; the host resolves privileged credentials and administrative destinations. Discovery reports state without installing. Explicit install creates denied registry state, and explicit grant or revoke coordinates that authoritative state with the upstream enforcement projection.

The work also improved integration contracts and the operator experience. Missing install handlers fail at service construction. The browser displays host state, exposes install, grant and revoke as explicit actions, suppresses duplicate pending actions, and re-reads authority after mutations. Generic credential provisioning replaces per-demo wiring while retaining separate scoped-bearer and privileged-admin credential classes.

Real browser and extension testing found defects that narrower tests missed: stale admin-revoke request bodies and malformed host-owned endpoint URLs, a certification environment running OpenCode 1.14.33 instead of the required 1.18.4, and a graphical assertion that could observe unrelated card text before grant completion. T7 additionally closed a fail-open upstream restart default and the missing grant-to-upstream convergence path.

Final independent results include Browser-first 2259 passed out of 2260, exit 0, no failures and one macOS-only test skipped on Linux; real graphical Extension 5/5; Browser-host 13/13; Security/adversarial 12/12; T2 focused gates 6/6 and 2/2; and artifact verification PASS. Unit/Vitest and SDK stages also passed. These results are scoped acceptance evidence, not a claim of universal security or production completeness.

Future hardening remains separate: a host-mediated proxy, credential expiry and rotation, encrypted storage, credential-file permission checks, finer operator consent, reconciliation tooling, reinstall semantics, and better documentation and finding-to-test traceability. None is being represented as an unresolved blocker to the accepted SDK-DEMO-003R work.

One reporting correction matters: the T7.1 record attributes the loose /granted/i match to “Grant requested capabilities.” That literal does not match. Source inspection identifies `installation.grantedCapabilities` in the card’s explanatory text as a valid premature match. The synchronization defect, exact-label correction and independent final PASS remain supported. Section 7 records the distinction transparently.

Contents and review disposition

Section	Topic	Page
1	Host authority and read-only discovery	4
2	Install contract and live integration findings	5
3	Revocation convergence	6
4	Operator lifecycle	7
5	Generic credentials and boundary hardening	8
6	Endpoint enforcement	9
7	Graphical integration closure	10
8	Final SDK authority model	11
9	Verification methodology and lineage	12
10	Final acceptance	13
11	Recommended future hardening	14
A	Exact commit lineage and evidence register	15
B	Finding-to-test and source traceability	16
C	Audit qualifications and report provenance	17

Review item matrix

Item	Accepted correction	Status
T1	Host-owned administrative authority	CLOSED
T2	Status and discovery do not install	CLOSED
T3	Required install handler and integration closure	CLOSED
T4	Registry and upstream revocation converge	CLOSED
T5	Explicit operator install, grant and revoke UI	CLOSED
T6	Generic host-owned credential provisioning	CLOSED
T6.1	Credential source and boundary hardening	CLOSED
T7	Closed startup and symmetric endpoint convergence	CLOSED
T7.1	Authoritative graphical-test synchronization	CLOSED

Closure refers to the accepted review scope at the final candidate, supported by the lineage and independent verification below. Deferred deployment and architecture work is listed separately.

1 Host authority and read-only discovery

T1 Host-owned administrative authority

Original finding. Administrative revoke accepted caller-controlled `upstreamAdminUrl` and `adminToken`. This allowed request data to determine privileged outbound authority. Investigation traced the request through the workspace host handler to the upstream administrative fetch. [S1]

REQUEST DESCRIBES INTENT.
HOST DETERMINES AUTHORITY.

Correction. The caller identifies the add-on and requested action. The host resolves the administrative destination and credential from host provisioning, keyed by add-on identity. The admin-revoke handler rejects any supplied `upstreamAdminUrl` or `adminToken` field with permission-denied before contacting the upstream. Missing host configuration denies the operation. The follow-up validation rejects null, arrays and other malformed request shapes as invalid-event instead of throwing a native destructuring error.

Verification. Commits `c54bbee5` and `5ee4dfd1` establish the boundary and malformed-input hardening. The adversarial suite covers caller injection, unconfigured add-ons and malformed requests; host-service regressions preserve required route wiring. The accepted cumulative T1–T3/live candidate is `c869a928`, independently passed in #28 after environment qualification. Status: CLOSED. [E28, S1, S4]

T2 Discovery reports state without installation

Original finding. `executeAddonsStatus` installed discovered manifests. Earlier re-poll protection reduced grant wiping but still made a status request an installation action. Investigation separated discovery projection, canonical manifest caching and registry mutation. [S1, S5]

READ/DISCOVERY REPORTS STATE.
EXPLICIT INSTALL MUTATES STATE.

Correction. Status now caches full canonical manifests for subsequent installation and projects installed/granted state from registry snapshots. It does not invoke `registry.install`, `grant` or `revoke`. Explicit installation is separate and grants nothing; requested capabilities begin denied. Existing grants survive status polling.

Verification. Six read-only tests cover initial discovery, repeated polling, explicit installation, duplicate prevention, discovery failure and registry-grant reporting. Two grant-regression tests protect grants across polling. T2-5 was strengthened to inject an actual discovery exception and assert discovery-failed, an empty result and unchanged empty registry state. Final independent results are 6/6 and 2/2. Status: CLOSED. [E51, S5]

Scope precision. Bootstrap retains a separate compatibility path that may register a cached, absent manifest with denied grants. T2 establishes read-only status/discovery; it does not establish that every route classified as “read” is free of registration side effects. Bootstrap never creates granted authority. [S1]

2 Install contract and live integration findings

T3 Required host contract

Making `executeWorkspaceAddonInstall` a required host-service handler exposed stale service constructions. The correction retained that contract: service construction fails fast when the handler is absent, and the install route remains wired with `addon-runtime-control`. T1-related fixture updates supplied the workspace handlers; T3 commit `4e7a144c` added an explicit missing-install-handler regression. This is contract and integration closure, not a new security architecture. Status: CLOSED. [S2, S6]

Admin-revoke HTTP 500 in the graphical path

Real extension tests failed for both Counter and SDK Guide with 500 rather than the expected 200. The investigation identified two distinct defects. First, both test clients still sent pre-T1 privileged URL/token fields. T1 correctly rejected those fields, but the then-current transport error mapping surfaced the rejection as HTTP 500. Second, the host mapping itself contained invalid Echo/Counter URLs with uninterpolated `${...}` strings and an incorrect SDK Guide port of 3403. [E25, S7]

Commit `c869a928` changed the live test bodies to intent-only `{ addonId, granted }` and corrected the host-owned destinations to the manifest-aligned loopback ports 47321, 47322 and 47323. It did not relax the injection guard. A new live-bridge regression exercised successful host mapping and injection denial; the engineering record reports that it failed before the correction and passed afterward. Both graphical lifecycle paths then passed, with the extension suite reaching 4/4. [E25]

The HTTP error-family improvement was completed separately: T4 gave `revoke/admin-revoke` the harness transport boundary, and T5 aligned `install/grant`. The final routes distinguish policy 4xx from runtime 5xx failures. T6 subsequently replaced the temporary literal per-demo destinations with generic provisioning. This chronology avoids attributing all later hardening to the HTTP 500 fix. [S2, S3]

OpenCode environment qualification

The certification environment resolved OpenCode 1.14.33 while `browser-first/host/opencode-version.json` required 1.18.4. This was an environment mismatch, not an SDK architecture defect. The environment qualification record reports upgrading the existing arm64 installation to exactly 1.18.4, verifying the SDK's trusted-root resolution and the version-pin scenario, and leaving SDK source and its expected version unchanged. [E27, S8]

The first `c869a928` verification still exposed the mismatch. The fresh independent #28 run on the same SHA passed after qualification: Browser-first 2213/2214 and Extension 4/4. The single excluded test was the platform-specific macOS sandbox test. Narrow green tests were therefore insufficient until the real path and its environment were qualified. [E28]

3 Revocation convergence

T4 One authority and its enforcement projection

Original finding. Registry revoke and the upstream administrative deny channel could change independently. A denied registry could coexist with an upstream still accepting a previously issued bearer, while upstream denial alone could leave registry state reporting grants. [S1, S9]

Registry grant state = authoritative source of truth
Upstream enforcement = projection of that authority

Correction. Both operator revoke surfaces converge registry grants and upstream enforcement. The shared convergence helper computes the target grant surface and coordinates the writes. Administrative revoke can deny the whole surface or perform the supported explicit regrant. Partial capability revoke preserves the other registry entries; the current upstream gate remains open while any capability is granted.

Transition	Order	Failure interpretation
DENY	1. Close upstream 2. Persist registry denial	If denial persistence fails after upstream closure, enforcement stays closed and the operation reports failure.
ALLOW	1. Persist registry grant 2. Open upstream	If upstream opening fails from a closed state, the registry may show a grant while enforcement stays closed; the operation reports failure.

This is not a distributed transaction. A successful return means both writes completed. Revision checks surface conflicting registry updates, and reapplying the same desired state supports retry. There is no claim of atomic cross-process commit or automatic recovery from every partial failure.

Failure boundary. The ordering avoids prematurely opening authority. It cannot guarantee remote closure if the initial upstream-close request itself fails against an already-open service; that revoke fails and must be retried. Likewise, lost acknowledgments cannot be equated with confirmed remote state. These distinctions are necessary when interpreting “fail closed.” [S1, S9]

Bootstrap and regression protection

Bootstrap derives token delivery from registry grants rather than manifest presets. Existing denied installations stay denied. If an installation is absent but a canonical manifest is cached, bootstrap may register it with denied grants; it does not restore prior grants or open enforcement. The regression tests cover this even after registry removal. [S1, S9]

Seven T4 tests cover both revoke channels, supported administrative regrant, bootstrap non-resurrection, privileged-field injection, upstream failure and retry/idempotence. Independent #39 passed c57d4d0f, including Browser-first 2220/2221 and graphical Extension 4/4. Status: CLOSED. T7 later completed ordinary /grant convergence and restart-safe upstream defaults; those were not already solved by T4. [E39]

4 Operator lifecycle

T5 Explicit actions and authoritative state

Discover -> Install -> Denied -> Grant -> Granted
Granted -> Revoke -> Denied

The Add-ons card exposes explicit operator installation, grant and revoke. Discovery alone offers installation and reports no granted authority. Install registers the add-on with denied capabilities. Grant requests currently outstanding capabilities; revoke requests withdrawal of the currently granted capabilities. [S10]

The browser does not invent authority. The displayed status and capability chips derive from the host registry projection returned by `/addons/status`. Manifest grant presets describe approvable requests; they are not current authority. The request shape preserves the declared capability scope and revocation behavior.

The operator UI installs with `{ addonId }`. The host resolves the canonical manifest from its discovery cache. The browser does not send an administrative URL or token, and it does not call upstream `/admin` routes directly. The service also retains a `{ manifest }` argument for existing host-side uses; the accepted change should not be overstated as a universal public payload allowlist. [S1, S2, S10]

Condition	Operator behavior
Mutation pending	Disable the add-on's action buttons and suppress duplicate requests.
Mutation succeeds	Re-read <code>/addons/status</code> ; show the host result rather than optimistically changing local authority.
Policy rejection	Show a 4xx policy error and re-read the host state.
Runtime or network failure	Show a failure or connection guidance and re-read when possible; do not report the action as successful.

State and action outcome are distinct. A partial grant failure can leave a persisted registry grant while upstream opening failed. An authoritative refresh may therefore show that grant together with a failure message; it must not be read as confirmation that enforcement has opened. Operator-visible reconciliation remains useful future work. [S1, S10]

Verification and graphical proof

Nine UI regressions cover discovered and denied state, grant/revoke refresh, policy/runtime errors, pending duplicate suppression, read-only refresh and absence of privileged fields. Five bridge tests cover installation state, canonical `addonId` resolution, unknown IDs and transport/error boundaries. [S11]

The real extension test exercises `Install -> Grant -> bearer HTTP 200 -> Revoke -> the same bearer HTTP 403`. Independent #41 accepted 20726e39 with Extension 5/5 and Browser-first 2234/2235. T7.1 later tightened the test's synchronization without changing this lifecycle or weakening enforcement. Status: CLOSED. [E41, E51, S12]

5 Generic credentials and boundary hardening

T6 Provision by identity and purpose

Earlier provisioning required per-demo token maps, literal administrative endpoints and bespoke flags/environment variables. Each new add-on required launcher changes. T6 replaced this wiring with workspace-addon-credentials.mjs, a host-owned resolver accepting add-on identity, credential purpose and, for endpoint derivation, the host's canonical manifest endpoint. [S3]

Class	Returned material	Permitted boundary
Scoped bearer	Add-on identity, purpose and token	May cross the sandbox/bootstrap boundary for host-granted capabilities.
Privileged admin	Add-on identity, purpose, administrative URL and token	Trusted host/admin channel only; never iframe, status or bootstrap.

Generic provisioning is not one undifferentiated bag of secrets. The resolver returns only the selected credential class. The operator-started upstream receives its own bearer and admin verification material; “host-only” excludes browser/add-on UI delivery, not the trusted upstream that validates the administrative call. Provisioning is config/environment-backed, loaded at startup into process memory, and rotation is restart-bound. No encrypted vault, per-grant minting or expiry is implemented.

T6.1 Audit corrections

The audit found raw credential JSON accepted through process argv, acceptance of 0.0.0.0 as an administrative destination, and wording that overstated resolver authentication. The raw-secret JSON flag is no longer read; a credential-file path is allowed. Source precedence is CLI file reference, environment file path, environment JSON, then an empty fail-closed configuration. The old raw flag alone provides no credentials. [S3, S13]

The documented destination policy is true loopback: 127.0.0.0/8, ::1 and localhost; 0.0.0.0 is rejected, as are tested external destinations and non-HTTP(S) schemes. The resolver is explicitly an internal lookup, not an authentication boundary. Trusted host call sites bind the requested identity to registry/install state and obtain endpoint context from the host-owned manifest cache before resolving credentials.

```
Trusted host caller -> authoritative add-on identity
-> credential resolver
```

Verification. Sixteen credential tests cover purpose separation, distinct add-ons, absent/invalid material, secret-free errors, provisioning precedence, raw-argv removal, bind-any rejection, accepted loopback cases, bootstrap bearer-only delivery and credential-free status. The audit documented production call sites. The initial T6 SHA 30197261 is superseded by b8735970, independently passed in #45. T6 and T6.1: CLOSED. [E45, S13]

6 Endpoint enforcement

T7 Close the startup and grant-direction gaps

Investigation found that Echo, Counter and SDK Guide initialized `hostGranted = true`. A restarted upstream therefore reopened mutating endpoints despite revoked registry authority, allowing a stale but valid bearer to become effective again. Ordinary `/addons/workspace/grant` changed the registry without opening upstream enforcement; revoke converged both layers, but ordinary regrant did not. [S1, S14]

T7 changed all three fresh upstream defaults to `hostGranted = false` and made ordinary grant converge through the host-owned administrative channel. It also rejected 0.0.0.0 discovery endpoints, aligning the discovery case with the T6.1 bind-any restriction. The correction closed the demonstrated gap without implementing the deferred host-mediated proxy.

Lifecycle event	Authoritative action and enforcement	Bearer result
Fresh upstream	Starts <code>hostGranted = false</code>	403
Explicit grant	Persist registry authority, then open upstream	200
Explicit revoke	Close upstream, then persist registry denial	403
Restart after revoke	Fresh process starts closed	403 for stale bearer
Explicit regrant	Persist grant, then reopen upstream	200

These results concern a valid configured bearer on the protected mutating API. Missing or incorrect authentication is a separate condition, typically 401; no configured bearer can produce 503. The in-memory gate is currently add-on-wide, based on whether any capability remains granted, rather than a general per-operation capability evaluator.

Endpoint and route verification

Eight endpoint regressions cover fresh denial across all three servers, grant success, converged revoke, stale-bearer denial after restart, regrant, unavailable-upstream failure, forged grant fields and bind-any discovery rejection. The route completeness audit inspects declared route metadata in both directions: every workspace route must be classified, and every classified route must exist. [S14, S15]

Install, grant, revoke and admin-revoke require `addon-runtime-control`, `loopbackHostOnly` and harness error mapping. Grants lookup and bootstrap require `addon-runtime-read`. A new unclassified `/addons/workspace/*` route fails the audit. Bootstrap's read classification does not remove its denied-registration compatibility behavior described in Section 1.

Candidate `f99667b4` passed the independent Browser-first stage but failed the graphical Extension stage; it was not accepted. Final closure uses corrected candidate `180f3067` and `#51`. T7 production enforcement is identical between those two candidates. Status: CLOSED at the final candidate. [E49, E51]

7 Graphical integration closure

T7.1 The failed candidate remains part of the record

Independent #49 tested f99667b4641a51861d65a4fad8e4bd7aa07e7e06 without source mutation. Browser-first passed 2259/2260, but Extension passed four of five tests and failed overall. The failing test was “T5 real extension exercises operator grant/revoke UI (install -> grant -> revoke),” with 403 !== 200. It was one failed test, not four failures. [E49]

The engineering investigation recorded that the card remained DENIED with a mutation pending when the whole-card wait returned. The subsequent bearer request could reach the upstream before grant convergence and correctly receive 403. The report records 9/12 full-suite failures before correction, passage in isolation, and 0/12 full-suite failures afterward. Those reproduction counts are engineering evidence; independent acceptance comes from #51. [E50]

Mechanically corrected explanation

The old helper polled `card.innerText()` with `/granted/i`. Both the work-order narrative and the committed findings incorrectly say this matched “Grant requested capabilities.” A direct JavaScript check shows that it does not. The actual card includes explanatory text mentioning `installation.grantedCapabilities`, which does match `/granted/i` regardless of the header’s authority status. The source therefore supports the premature whole-card match and race, but not the stated button-label attribution. [S10, S12, S16]

```
/granted/i.test("Grant requested capabilities") // false
/granted/i.test("installation.grantedCapabilities") // true
```

Correction and acceptance

T7.1 restricts the wait to the dedicated `.addon-card-header` span and compares its trimmed value case-insensitively with the exact expected state: Discovered, Denied or Granted. The bearer request is issued only after the authoritative label reaches Granted, following the UI’s completed mutation and re-read. It no longer treats arbitrary card prose as a completion signal.

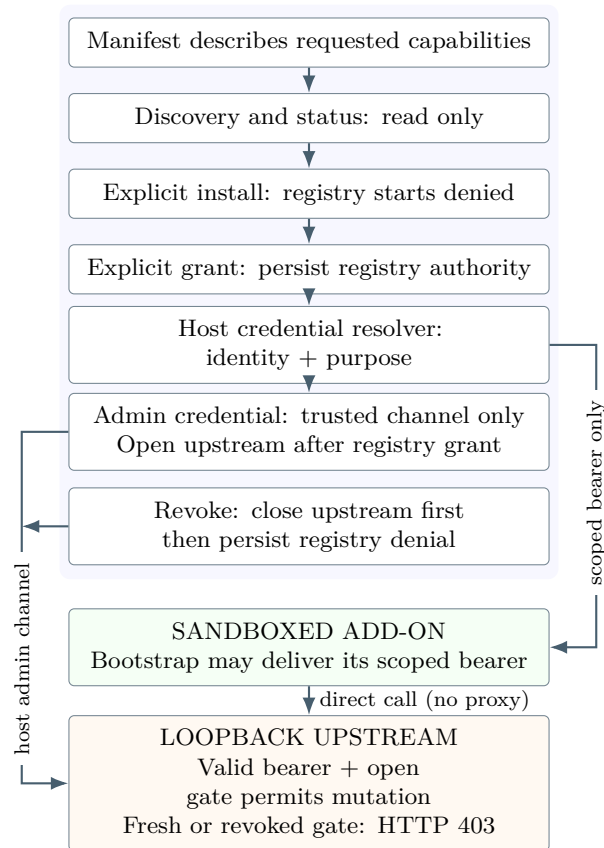
```
text.trim().toLowerCase() === label.toLowerCase()
```

The final diff changes only the graphical test and `SDK-DEMO-003-FINDINGS.md`. It makes no production-source change and does not weaken the fail-closed endpoint. Existing endpoint tests separately assert registry grant, upstream gate state and HTTP result; the graphical test verifies the real operator sequence.

Independent #51 then passed the corrected exact SHA with Extension 5/5 and all cumulative gates green. The rejected T7 candidate is retained in the lineage because it demonstrates why engineering PASS and isolated success were not sufficient acceptance evidence. Status: CLOSED. [E51]

8 Final SDK authority model

TRUSTED HOST AND OPERATOR CONTROL



The manifest describes requested capabilities. Discovery caches canonical definitions and projects state. Explicit installation creates denied registry entries; explicit host grant persists authority before opening the upstream. Revocation closes upstream enforcement before persisting denial. Bootstrap delivers only scoped bearer material for granted capabilities. [S1–S3, S10, S14]

The browser is an intent and display surface. The trusted host owns administrative resolution. The sandboxed add-on still calls its own loopback upstream directly; that upstream checks its bearer and hostGranted gate. A bridge-owned proxy is not implemented. The diagram shows the normal explicit-install path; bootstrap's denied-registration compatibility path is described in Section 1.

The resolver trusts its host caller's identity binding. Admin material belongs only to trusted host/upstream administration. A scoped bearer can intentionally reach the add-on boundary; the two credential classes are never interchangeable.

9 Verification methodology and lineage

Engineering PASS was deliberately not treated as final acceptance. Each milestone produced an exact candidate SHA for independent deterministic verification by VIGIL Test Lab. Verification included the real graphical Chromium/extension path and artifact checks; a failure returned the candidate for correction. The final source and evidence audit checks that the accepted code, test changes and machine record agree.

```
Build -> exact candidate SHA -> independent verification
-> graphical Chromium/extension -> code/evidence audit
-> accept or issue corrective work
```

Milestone	Candidate	Independent result	Evidence
T1–T3 + live	c869a928	PASS; Extension 4/4	[E28]
T4	c57d4d0f	PASS; Extension 4/4	[E39]
T5	20726e39	PASS; Extension 5/5	[E41]
T6 initial	30197261	Superseded; not final T6 acceptance	[E43]
T6/T6.1	b8735970	PASS; Extension 5/5	[E45]
T7 initial	f99667b4	FAIL; Extension 4/5	[E49]
T7/T7.1 final	180f3067	PASS; Extension 5/5	[E51]

Git inspection confirms an unbroken ancestor chain through these milestones. The final commit's parent is f99667b4, whose parent is b8735970. Branch tips fetched for inspection match the supplied milestone SHAs. Appendix A gives all full identifiers and exact final-machine-report references.

What the evidence establishes

Unit and SDK tests protect contracts and focused behavior. Host and adversarial tests exercise route boundaries and hostile inputs. Browser-first provides broad regression coverage. Graphical extension tests demonstrate integration through the actual operator UI, bridge and upstream services. Artifact verification and matching candidate/actual SHAs bind the result to the tested source state.

These layers are complementary. Some adversarial checks are static shape assertions rather than runtime attacks, and token-rejection tests do not measure constant-time behavior. The findings record makes these distinctions explicitly. Suite counts must not be treated as exhaustive proofs of all security properties. [S16]

For this report, ten focused Node test files were re-run on the final candidate: 74/74 passed with no skips. That corroborating local run is separate from, and does not replace, the qualified independent #51 graphical acceptance run. [A1]

10 Final acceptance

Final accepted SDK-DEMO-003R candidate:

180f3067906d4782df5b923ca46ef77b80828333

Independent final-machine-report result: PASS. Candidate SHA and actual tested SHA are identical. Source mutation: none. Run: run-2026-09-28-14-01-32Z-180f3067-99c8. [E51]

Stage	Final independent result	Exit
Unit / Vitest	PASS; no count stated in machine summary	0
SDK tests	PASS; no count stated in machine summary	0
Browser-host	13/13 PASS	0
Security / adversarial	12/12 PASS	0
T2 status read-only	6/6 PASS	0
T2 status grant regression	2/2 PASS	0
Browser-first	2259/2260 PASS; 0 failures; 1 skip	0
Real graphical Extension	5/5 PASS	0
Artifact verification	PASS	Not specified

The one Browser-first skip is the macOS sandbox-exec isolation test on the Linux verification platform. The committed platform guard and the T7.1 engineering record identify this skip; the independent machine summary confirms the aggregate count and exit 0. No failed test is being recast as a skip. [E50, E51, S17]

Accepted disposition

T1	T2	T3	T4	T5	T6	T6.1	T7	T7.1
CLOSED	CLOSED	CLOSED	CLOSED	CLOSED	CLOSED	CLOSED	CLOSED	CLOSED

Conclusion

SDK-DEMO-003R review and acceptance work is complete at the stated SHA. Tom's findings led to corrected authority ownership, read-only status, retained install contracts, converged revocation, explicit operator controls, generic credential classes and restart-safe endpoint denial. Independent graphical testing also exposed and closed an evidence-synchronization defect.

This conclusion is scoped to the demonstrated SDK review work and the recorded verification environment. It does not claim production completeness, universal atomicity, live credential rotation, encrypted storage or a host-mediated proxy. The recommended work on the next page is future hardening, not a restatement of failed acceptance items.

11 Recommended future hardening

RECOMMENDED FUTURE HARDENING — NOT CURRENT ACCEPTANCE BLOCKERS

Area	Current state and recommended next work
Host-mediated enforcement proxy	The iframe still calls its own loopback upstream. Consider routing mutating traffic through a bridge-owned proxy that checks current grants before forwarding. This is not implemented.
Credential rotation and expiry	Provisioning is startup-loaded and restart-bound. Consider per-grant minting, expiry, audience binding and rotation on revoke, with coordinated upstream updates.
Encrypted-at-rest storage	No encrypted credential vault exists. Define a protected store and its unlock/lifecycle model before making storage-security claims.
Credential-file owner and mode	The loader does not enforce ownership or file mode. Validate owner-only access, such as 0600 where appropriate, and handle deployment-specific exceptions explicitly.
Per-capability operator consent	The UI can grant all outstanding requested capabilities together. Consider individual toggles and per-operation enforcement as the capability surface grows.
Partial-failure reconciliation	Expose desired registry state, observed enforcement state and retry status. Handle safe split states and unsuccessful upstream contact without implying successful convergence.
Registry reinstall semantics	Audit and specify whether identical reinstall should reject, no-op or intentionally reset grants. Current registry.install replaces state and resets grants.
Finding-to-test traceability	Maintain a durable map from each closed finding to tests, exact acceptance evidence and test limitations; keep the graphical gate explicit.
Documentation reachability	Resolve the six existing unreachable milestone-document findings separately. Preserve the accepted source state while improving navigation and correcting stale explanations.

The priority and design of these changes should be agreed as new work. T7's endpoint correction deliberately did not absorb the larger proxy, token-lifecycle or vault projects. The current milestone's accepted state remains the one independently verified in #51.

Appendix A Exact lineage and evidence register

Repository: vonstegen/2.0.0-alpha. Full Git identifiers below were inspected mechanically; each listed successor descends from the prior milestone.

T1–T3 and live integration [c869a92841511fc444ef42772bdae2e985303890](#)

T4 [c57d4d0f579f601de91fcf3b7d7faca343d68c7d](#)

T5 [20726e395909e135782205d7fdad37d481aa5400](#)

T6 initial — superseded [30197261cb179a43126fc0890dd56de9354ffec9](#)

T6 and T6.1 — accepted [b8735970315a8f5ab4a4656dfe6702d31ad47d13](#)

T7 initial — independent FAIL [f99667b4641a51861d65a4fad8e4bd7aa07e7e06](#)

T7 and T7.1 — final accepted [180f3067906d4782df5b923ca46ef77b80828333](#)

GitHub evidence

E25 [Live admin-revoke diagnosis and correction](#)

E27 [OpenCode environment qualification](#)

E28 [T1–T3/live independent final PASS](#)

E39 [T4 independent final PASS](#)

E41 [T5 independent final PASS](#)

E43 [Initial T6 verification request; superseded](#)

E45 [T6.1 independent final PASS](#)

E49 [Initial T7 final FAIL and 403 mismatch](#)

E50 [T7.1 engineering diagnosis and reproduction](#)

E51 [Final corrected exact-SHA machine PASS](#)

Evidence was inspected on 28 September 2026. Issue comments are linked directly where their identifiers were available. Engineering reproduction records and independent acceptance results are distinguished throughout.

Appendix B Finding-to-test traceability

The following paths are in the final accepted tree. Click a source label to open the exact-SHA GitHub file. Test counts below describe the named focused files, not the total acceptance plan.

Item	Focused regression witnesses	Independent gate
T1	S4: injection, missing configuration, malformed input	12/12 adversarial
T2	S5: 6 cases; addons-status-grant-regression.test.mjs: 2 cases	6/6 and 2/2
T3	S6: required install handler, route and capability retained	Cumulative #28/#51
Live fix	S7: real bridge; Counter and Guide graphical lifecycle tests	Extension 4/4 at #28
T4	S9: 7 convergence and bootstrap cases	Cumulative #39/#51
T5	S11: 9 UI tests; addon-grant-revoke-bridge.test.mjs: 5 tests; S12: graphical lifecycle	Extension 5/5
T6/6.1	S13: 16 resolver, provisioning and projection tests	Cumulative #45/#51
T7	S14: 8 endpoint tests; S15: route completeness	Cumulative #51
T7.1	S12: exact header-state synchronization before bearer call	Extension 5/5 at #51

Primary implementation and architecture

S1 `browser-first/host/addon-delegation-service.mjs`

S2 `browser-first/host/addon-delegation-host-service.mjs`

S3 `browser-first/host/workspace-addon-credentials.mjs`

S10 `browser-first/resonantos-side-panel-extension/src/lib/main-workspace-addons.js`

S16 `SDK-DEMO-003-FINDINGS.md`

Architecture map `SDK-DEMO-003-ARCHITECTURE-MAP.md`

The architecture map contains historical baseline sections. Current behavior in this report is resolved from final source and commit diffs, not from treating every historical statement as current.

Appendix C Audit qualifications and report provenance

Source and test links

S4 browser-first/test/sd003-p8-adversarial.test.mjs
S5 browser-first/test/addons-status-read-only.test.mjs
S6 browser-first/test/addon-delegation-host-service.test.mjs
S7 browser-first/test/addons-admin-revoke-live-bridge.test.mjs
S8 browser-first/host/opencode-version.json
S9 browser-first/test/addons-revocation-convergence.test.mjs
S11 browser-first/test/addon-grant-revoke-ui.test.mjs
S12 examples/sdk-demo/tests/t5-grant-revoke-ui-extension-live.test.mjs
S13 browser-first/test/workspace-addon-credentials.test.mjs
S14 browser-first/test/sd003r-t7-endpoint-enforcement.test.mjs
S15 browser-first/test/bridge-route-capability-audit.test.mjs
S17 browser-first/test/delegation-isolation-live.test.mjs

A1 Mechanical inspection and corroboration

The report audit fetched the SDK-DEMO-003R branches into an isolated local repository, checked out the final SHA detached, inspected milestone commit diffs, route definitions, handlers, UI code, upstream servers, focused tests, findings and architecture records, and cross-checked the linked GitHub machine reports. No SDK production source was edited.

A local Node v26.0.0 run executed ten focused files: S4, S5, S6, S9, S11, S13, S14, S15, addons-status-grant-regression.test.mjs and addon-grant-revoke-bridge.test.mjs. Result: 74 tests, 74 passed, zero failed, zero skipped, exit 0. The qualified graphical and broad acceptance figures remain attributed to independent #51; this local audit did not repeat that full environment certification.

Precision limits for architectural claims

The accepted credential guard explicitly rejects 0.0.0.0 and tests the documented loopback cases. Its 127.* branch is a hostname-prefix check; it should not be described as a comprehensive IP/DNS/redirect security proof. Additional destination validation belongs in future hardening if provisioning becomes less trusted. The resolver likewise does not authenticate arbitrary callers.

The public UI's addonId install path resolves canonical host state, but the service retains a manifest argument. Bootstrap can register an absent cached manifest with denied grants. The upstream gate is add-on-wide and in-memory. Failed contact cannot certify a remote transition. These qualifications describe the accepted implementation and prevent broader claims than the code or tests support.

The T7.1 narrative's literal regex attribution is corrected in Section 7. The existing findings/architecture documents otherwise serve as review history; they are not substitutes for the source and exact-SHA verification record. No deferred hardening was implemented as part of preparing this report.